RAM ENTERPRISE P&P WBS STRUCTURE – 07_Risk_Compliance

07_Risk_Compliance

(RAM Policies & Procedures Manual – WBS Structured Framework)

07.1 Enterprise Risk Management (ERM) Policy

Purpose: Establish structured risk identification, assessment, mitigation, and monitoring aligned with **ISO 31000**, **ISO 37301**, and **COSO ERM** frameworks.

07.1.1 Risk Governance Structure

07.1.1.1 Board Risk Oversight

- Approves Risk Appetite Statement
- Reviews quarterly risk dashboard
- Oversees major strategic risks

07.1.1.2 Executive Risk Committee (ERC)

- Reviews enterprise risk register
- Escalates high/critical risks
- Monitors mitigation plans

07.1.1.3 Risk Owners

- Identify and assess operational risks
- Maintain departmental risk registers
- Report incidents & mitigation status

07.1.2 Risk Management Procedure

07.1.2.1 Risk Identification

- Strategic risks
- Financial risks
- Operational risks
- Compliance risks
- ESG & sustainability risks
- IT & Cyber risks

Form:

- F-07.1-R01 Risk Identification Template

07.1.2.2 Risk Assessment

Step	Description
1	Define likelihood (1–5 scale)
2	Define impact (1–5 scale)
3	Calculate inherent risk score
4	Evaluate existing controls
5	Calculate residual risk

Form:

- F-07.1-R02 Risk Assessment Matrix

07.1.2.3 Risk Treatment

- Avoid
- Reduce
- Transfer
- Accept

Form:

- F-07.1-R03 Risk Mitigation Plan

07.1.2.4 Risk Monitoring & Reporting

- Quarterly Risk Dashboard
- Heat Map Visualization
- Escalation Protocol

Form:

- F-07.1-R04 Risk Reporting Template

07.2 Compliance Management System (CMS)

Aligned with **ISO 37301**

07.2.1 Compliance Governance

07.2.1.1 Compliance Officer

- Maintains compliance register
- Reviews regulatory updates
- Coordinates audits

07.2.1.2 Legal & Regulatory Monitoring

- Local laws
- Real estate regulations
- ESG requirements
- Labor laws
- Tax laws

Form:

- F-07.2-C01 Regulatory Register

07.2.2 Policy Management Procedure

07.2.2.1 Policy Drafting

07.2.2.2 Policy Review

07.2.2.3 Approval Workflow

07.2.2.4 Policy Communication

07.2.2.5 Policy Annual Review

Form:

- F-07.2-C02 Policy Lifecycle Tracker

07.2.3 Whistleblowing & Ethics Procedure

07.2.3.1 Reporting Channels

- Anonymous email
- Hotline
- Secure web portal

07.2.3.2 Investigation Protocol

- Case registration
- Independent review
- Evidence documentation
- Decision & corrective action

Form:

- F-07.2-C03 Ethics Case Log

07.3 Internal Control Framework

Aligned with **COSO Internal Control Framework**

07.3.1 Control Environment

- Code of Conduct
- Segregation of Duties
- Delegation of Authority Matrix

07.3.2 Risk & Control Matrix (RCM)

Risk ID Process Risk Description Control Owner Frequency Evidence

Form:

- F-07.3-I01 Risk & Control Matrix Template

07.3.3 Control Testing Procedure

07.3.3.1 Annual Testing Plan

07.3.3.2 Sample Selection

07.3.3.3 Evidence Review

07.3.3.4 Control Effectiveness Rating

Ratings:

- Effective

- Partially Effective
- Ineffective

Form:

- F-07.3-I02 Control Testing Worksheet

07.4 Anti-Fraud & Anti-Corruption Policy

07.4.1 Fraud Risk Assessment

- Procurement fraud
- Leasing manipulation
- CapEx kickbacks
- Financial misstatement

07.4.2 Investigation & Disciplinary Process

- Case escalation
- HR involvement
- Legal notification
- Remediation plan

Form:

- F-07.4-A01 Fraud Investigation Report

07.5 Business Continuity & Crisis Management

07.5.1 Business Continuity Plan (BCP)

- Critical process identification
- Recovery Time Objective (RTO)
- Recovery Point Objective (RPO)
- Backup sites

07.5.2 Crisis Response Team Structure

- Crisis Leader
- Communications Lead
- Operations Lead
- Legal Lead

Form:

- F-07.5-B01 Business Impact Analysis Template

🔷 Integrated Governance, Risk & Compliance (GRC) Flow

```
Risk Identification → Risk Assessment → Control Design → Monitoring →
Compliance Check → Reporting → Board Oversight
```

🔷 Key Deliverables Under 07_Risk_Compliance

Deliverable	Frequency
Enterprise Risk Register	Quarterly
Compliance Register	Monthly Update
Risk Dashboard	Quarterly
Internal Control Testing Report	Annually
Fraud Risk Assessment	Annually
BCP Test Simulation Report	Annually

Check these

1 Full ISO 37301-aligned Compliance Manual text version
2 Full COSO-based Risk & Control Matrix (pre-filled for RAM real estate)
3 Visual BPMN diagrams for ERM & Compliance
4 Integrated GRC Dashboard structure
5 Convert entire 07 section into ready-to-use Policy Manual format (Word structure)